Report 3 – Scansione finale

Verifica dell'efficacia delle azioni di rimedio su Metasploitable2

1. Introduzione

Studente	Squicciarino Donato
Esercizio	Esercizio finale W12D4
Corso	Epicode – Cybersecurity & Ethical Hacker
Documento	Report 3 di 3 – ScansioneFine
Target	Metasploitable2 (192.168.51.101)
Strumento	Nessus Essentials – policy "Scansione di rete di base", la stessa della scansione iniziale
Scansione finale	4 ottobre 2026, dalle 8:17 alle 8:38 (21 minuti)

Questo report presenta i risultati della scansione eseguita dopo le azioni di rimedio e li confronta con la scansione iniziale, per dimostrare l'efficacia degli interventi. La descrizione delle vulnerabilità e i passaggi eseguiti non vengono ripresi: si rimanda al Report 1 (ScansioneInizio) e al Report 2 (RemediationMeta). Qui vengono invece spiegati i risultati e il motivo per cui alcune criticità sono rimaste.

2. Risultati della scansione finale

La scansione è stata eseguita sullo stesso target, con la stessa policy e con una durata identica a quella iniziale (21 minuti), così che il confronto sia valido. Il numero totale di risultati scende da 70 a 55 e, nel grafico a ciambella, la quota di vulnerabilità critiche è ora molto ridotta.

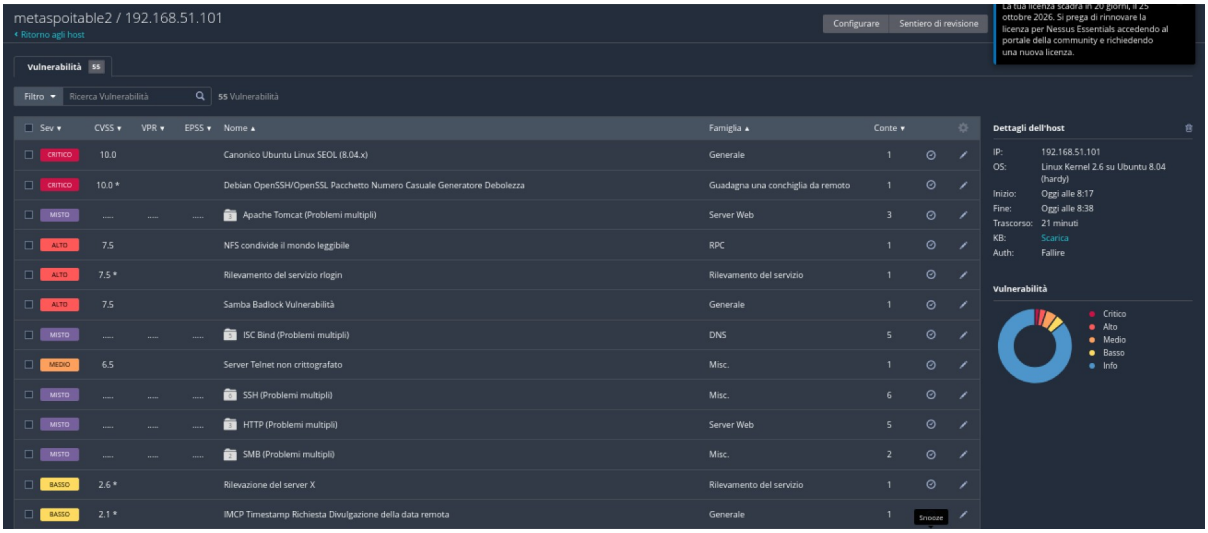


Figura 1 – Risultati della scansione finale su Metasploitable2 (4 ottobre 2026)

Tra le voci di gravità critica ne restano soltanto tre: Canonical Ubuntu Linux SEOL (8.04.x), Debian OpenSSH/OpenSSL Random Number Generator Weakness, ora con una sola occorrenza, e il gruppo Apache Tomcat, ora di 3 voci, che comprende ancora l'avviso di fine supporto del software. Nessuna delle quattro criticità selezionate compare più nell'elenco.

3. Confronto con la scansione iniziale

Dato	Scansione iniziale	Scansione finale
Data e ora	29 settembre, 15:44–16:05	4 ottobre, 8:17–8:38
Durata	21 minuti	21 minuti
Vulnerabilità totali	70	55
Criticità selezionate presenti	4	0

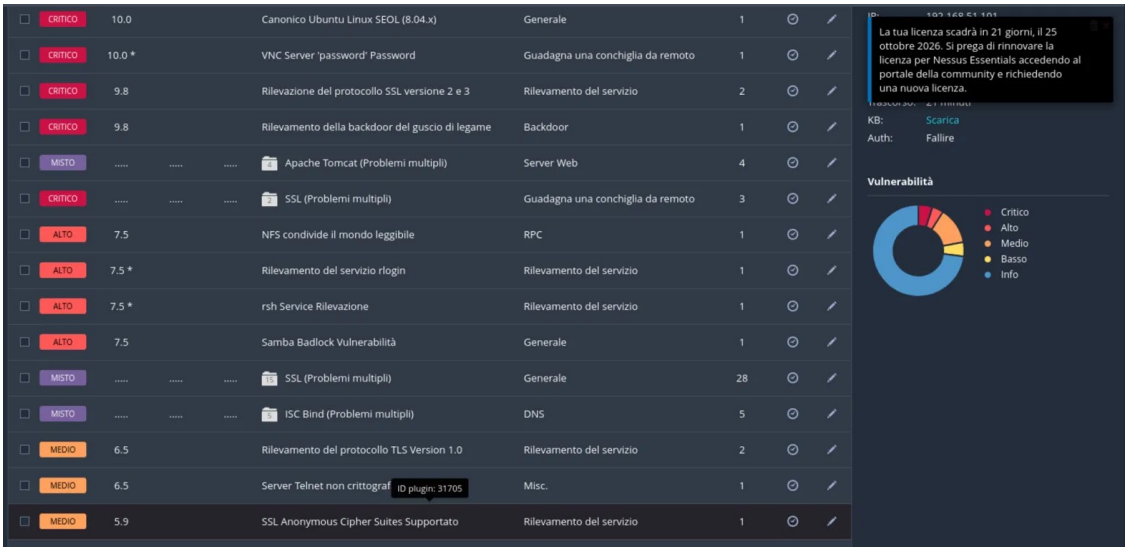


Figura 2 – Scansione iniziale (dal Report 1), da confrontare con la Figura 1

3.1 Le quattro criticità selezionate

Vulnerabilità	Porta	Scansione iniziale	Scansione finale
VNC Server 'password' Password	5900/tcp	Presente (CVSS 10.0)	Non più presente
SSL Version 2 and 3 Protocol Detection	25/tcp e 5432/tcp	Presente (CVSS 9.8, 2 occorrenze)	Non più presente
Bind Shell Backdoor Detection	1524/tcp	Presente (CVSS 9.8)	Non più presente
Apache Tomcat AJP (Ghostcat)	8009/tcp	Presente (gruppo Tomcat di 4 voci)	Non più presente (gruppo di 3 voci)

Le quattro vulnerabilità su cui si è intervenuto non vengono più rilevate da Nessus: la scansione conferma quanto già dimostrato con le prove manuali del Report 2.

3.2 Effetti indiretti

La disattivazione di SSL su Postfix e PostgreSQL ha prodotto anche altri miglioramenti non cercati direttamente:

- **Debian OpenSSH/OpenSSL:** le occorrenze critiche passano da 3 a 1. Le due legate ai servizi con SSL (SMTP e PostgreSQL) non vengono più rilevate perché i due servizi non offrono più cifratura.
- **Voci di gravità media:** non compaiono più TLS Version 1.0 Detection (6.5) e SSL Anonymous Cipher Suites Supported (5.9), né i gruppi di problemi SSL presenti nella scansione iniziale.
- **Gruppo Apache Tomcat:** da 4 a 3 voci, a seguito del blocco della porta 8009.

Una differenza non attribuibile agli interventi. La voce rsh Service Detection (gravità alta) presente nella scansione iniziale non compare nell'elenco finale. Non essendo stata oggetto di alcun intervento, non viene conteggiata tra i risultati dell'esercizio.

4. Perché sono state risolte solo quattro criticità

La traccia dell'esercizio chiedeva di scegliere da un minimo di 2 a un massimo di 4 vulnerabilità critiche su cui implementare azioni di rimedio, con la possibilità di usare regole firewall al massimo per una vulnerabilità. Il lavoro è quindi stato limitato di proposito a quattro criticità, scelte e motivate nel Report 1.

Lo scopo della scansione finale non è azzerare le vulnerabilità del sistema, ma dimostrare con un confronto misurabile che le azioni scelte funzionano. Le voci rimaste non sono quindi dimenticanze, ma un risultato atteso e coerente con la consegna.

5. Perché alcune criticità non possono essere risolte

5.1 Non sono problemi di configurazione

Le tre criticità rimaste (Ubuntu SEOL, Tomcat obsoleto e il difetto di Debian OpenSSH/OpenSSL) derivano dall'uso di software non più mantenuto. Nessuna impostazione può sostituire le correzioni che il produttore ha smesso di rilasciare: la soluzione richiede di sostituire o aggiornare il componente, non di modificarne la configurazione. Per questo, a differenza di VNC, bind shell e SSL, non esiste un intervento mirato e breve che le elimini. La soluzione teorica è descritta nel Report 2 (paragrafo 8).

5.2 Perché non è fattibile in questo contesto

- **Il target è volutamente vulnerabile.** Metasploitable2 è una macchina costruita come bersaglio didattico. Aggiornare il sistema operativo e tutti i servizi significherebbe sostituirla con un sistema diverso, che non sarebbe più il target dell'esercizio.
- **In un ambiente reale servirebbe un processo, non un comando.** Aggiornare software così datato comporta test di compatibilità con le applicazioni che ne dipendono, finestre di manutenzione, backup e un piano di ripristino in caso di problemi.
- **Rischio di interrompere i servizi.** Sistema e servizi legacy sono spesso legati a versioni specifiche, e un aggiornamento può rendere inutilizzabili funzioni su cui altri sistemi fanno affidamento.

5.3 Le altre vulnerabilità presenti

Restano nell'elenco anche voci di gravità alta, media e bassa, come NFS condiviso in lettura, rlogin, Samba Badlock, ISC Bind e Telnet non cifrato. Non rientrano nell'ambito dell'esercizio, limitato alle vulnerabilità critiche, e derivano da servizi legacy installati di default: per eliminarle bisognerebbe disattivare o aggiornare i servizi stessi.

5.4 Rischio residuo

Due degli interventi eseguiti sono mitigazioni e non correzioni definitive. Su SSL si è tolta la cifratura debole, ma il traffico ora non è cifrato; su Ghostcat la porta è nascosta dal firewall, ma Tomcat resta vulnerabile. Nessus non rileva più queste vulnerabilità perché il servizio non è più raggiungibile in quel modo, non perché il software sia stato aggiornato. I dettagli e la soluzione definitiva sono nel Report 2.

6. Conclusioni

La scansione finale conferma l'efficacia delle azioni di rimedio: le quattro criticità selezionate (VNC con password debole, SSL 2/3, bind shell backdoor e Ghostcat) non sono più presenti, e il totale

delle vulnerabilità rilevate scende da 70 a 55, con alcuni miglioramenti indiretti sulle voci legate a SSL. Le criticità rimaste dipendono dall'obsolescenza del sistema e dei suoi componenti e non erano comprese nell'ambito scelto per l'esercizio. Il percorso seguito (scansione iniziale, remediation documentata e scansione finale con la stessa policy) mostra un ciclo completo di gestione delle vulnerabilità e dei suoi limiti.